RAPPORT D'AUDIT GÉNÉRAL & SÉCURITÉ

Évaluation Technique, Vulnérabilités & Conformité Métier — Al Barid Bank (ABB)

Plateforme : Recrutement CCP / Al Barid Bank	**Stack :** MERN (MongoDB, Express, React 17, Node 24)
Périmètre : Code source, API REST, Authentification, Scoring, S3	**Score Global : 6.5 / 10 (65 / 100) — Risques critiques identifiés**

1. Synthèse de l'Évaluation & Scores Attribués

Axe d'Évaluation	Note / 10	Note / 100	Diagnostic Synthétique & Appréciation
Idée & Couverture Métier	**9.0 / 10**	**90%**	Workflow bancaire complet (Double contrôle, notation OFPPT/Année/Semestre, CV, CNI, statuts).
Interface & UX	**7.5 / 10**	**75%**	Dashboards réactifs, filtres, export CSV/Excel, formulaires par étapes clairs et intuitifs.
Architecture & Structure	**7.0 / 10**	**70%**	Architecture MVC propre (Routes / Contrôleurs / Modèles Mongoose bien séparés).
Qualité du Code & Fiabilité	**5.5 / 10**	**55%**	Bug majeur de concaténation de chaînes dans le calcul d'expérience. Code orphelin présent.
Sécurité Applicative (AppSec)	**3.5 / 10**	**35%**	Vulnérabilités critiques : Escalade Admin (Mass Assignment), IDOR sur les dossiers, clés S3 client.
■ SCORE GLOBAL PONDÉRÉ	**6.5 / 10**	**65%**	**Excellente base métier nécessitant un durcissement de sécurité prioritaire avant production.**

2. Vulnérabilités de Sécurité Détectées (OWASP Top 10)

Vulnérabilité & Emplacement	Sévérité	Description du Risque & Mécanique de la Faille
Mass Assignment à l'Inscription userControllers.js:20-39	**CRITIQUE (CVSS 9.1)**	Le contrôleur d'inscription public accepte isAdmin: true directement dans le corps JSON de la requête. N'importe qui peut s'inscrire en tant que Super-Administrateur.
Escalade de Privilèges sur Update userRoutes.js:26 / userControllers.js:248	**CRITIQUE (CVSS 8.8)**	La route PUT /api/users/:id ne vérifie pas les privilèges administrateur. Tout candidat connecté peut modifier son propre compte et s'octroyer le rôle isAdmin.
IDOR sur les Candidatures candidatureControllers.js:144	**ÉLEVÉE (CVSS 7.5)**	La route GET /api/candidatures/:id ne vérifie pas la propriété du dossier. Tout candidat peut consulter et extraire les dossiers, CIN et notes des autres candidats.
Secrets AWS S3 dans le Frontend InformationsPersonnellesScreen.js	**ÉLEVÉE (CVSS 7.4)**	Le SDK AWS est instancié côté client dans React avec accessKeyId et secretAccessKey visibles publiquement dans les sources JS inspectées.
Confusion des Rôles Middleware authMiddleware.js:33	**MOYENNE (CVSS 5.3)**	Le middleware admin valide également les contrôleurs et maîtres d'ouvrage pour des actions sensibles réservées aux administrateurs (ex: suppression de comptes).
Mot de passe hashé non filtré authMiddleware.js:15	**FAIBLE (CVSS 4.0)**	Le middleware utilise .select('-password') au lieu de .select('-mdp'). Le hash bcrypt du mot de passe reste donc attaché en mémoire à req.user.

3. Qualité du Code Source & Logique Métier

A. Bug Critique dans l'Algorithme de Notation d'Expérience :

Dans backend/utils/controleCondidat.js (lignes 136-141), la méthode toFixed(2) renvoie un **String**. L'instruction DureeMax = DureeMax + exp.duree; effectue donc une **concaténation textuelle** au lieu d'une addition arithmétique (ex: 6 mois + 12 mois = '06.0012.00'). Ce bug fausse entièrement le classement et le score d'expérience attribué aux candidats.

B. Artefacts de Code Mort & Configuration Statique :

• Présence d'un chiffre orphelin 353; après le return dans controleCondidat.js (ligne 159).
• Clé API SendGrid hardcodée avec une valeur factice sgMail.setApiKey('ss') dans sendMail.js au lieu d'utiliser la variable d'environnement SENDGRID_API_KEY.

C. Architecture Frontend & Évolution Récente :

• **Compatibilité Node 24 :** Résolution appliquée avec succès via le flag --openssl-legacy-provider.
• **Module de Publication d'Offres :** Création réussie du modèle, des contrôleurs, de l'écran admin AdminOffresScreen.js et du chargement dynamique sur la page d'accueil.
• **Redux Store :** Structure bien segmentée en actions / reducers / constants.

4. Plan d'Action Recommandé (Roadmap de Sécurisation)

Priorité 1 — Correctifs Immédiats (< 2 heures) :

1. Forcer isAdmin: false, isController: false, isMaitreOuvrage: false dans registerUser.
2. Restreindre la route PUT /api/users/:id avec le middleware admin strict.
3. Corriger le calcul d'expérience avec parseFloat() dans controleCondidat.js.
4. Remplacer .select('-password') par .select('-mdp') dans authMiddleware.js.

Priorité 2 — Sécurisation des Données & Fichiers (Court Terme) :

1. Transférer l'upload S3 vers le backend Express via multer-s3 ou des *Presigned URLs* pour supprimer tout identifiant AWS du code client.
2. Mettre en place express-rate-limit sur les endpoints d'authentification contre le brute-force.
3. Vérifier que seul le propriétaire ou un contrôleur/admin peut accéder à GET /api/candidatures/:id.

CONCLUSION DE L'AUDIT TECHNIQUE :
La plateforme dispose d'un socle fonctionnel solide et fidèle aux règles de gestion des concours d'Al Barid Bank. L'intégration récente du module de **Publication Dynamique d'Offres** complète le workflow métier. Dès l'application des correctifs de sécurité prioritaires mentionnés ci-dessus, le système atteindra un niveau d'excellence et de robustesse estimé à **9.2 / 10**.